

CyroPay Ltd

ISO 27001:2022 Gap Assessment Report

Document Type: GRC Assessment Report
Organisation: CyroPay Ltd — FinTech Payment Services, London UK
Assessment Scope: ISO 27001:2022 Annex A | Risk Register | DORA / GDPR Alignment
Assessment Date: June 2025
Prepared By: GRC Advisory Practice
Classification: CONFIDENTIAL — For Senior Management Only

RISKS ASSESSED 10 3 Critical · 3 High · 4 Medium	CRITICAL RISKS 3 Require immediate action
CONTROLS ASSESSED 93 Against ISO 27001:2022 Annex A	COMPLIANT 24 26% · 47% Partial · 27% Non-Compliant

This report is based on documentary review, staff interviews, and technical observation conducted in June 2025. It is intended for the Board and Senior Leadership Team.

1. Executive Summary

CyroPay Ltd is a UK-regulated FinTech payment services company headquartered in London, employing 120 staff and serving customers across the UK and EU. Operating under FCA authorisation and subject to UK GDPR, DORA, and PCI DSS obligations, CyroPay processes sensitive payment data and personally identifiable information at scale. This report presents the findings of an independent ISO 27001:2022 gap assessment conducted in June 2025.

The assessment evaluated 93 Annex A controls across four categories — Organisational, People, Physical, and Technological — and identified 10 risks across the organisation's information security landscape. The overall picture is one of a business with some foundational security measures in place, but with material gaps that carry genuine regulatory and operational risk.

1.1 Overall Assessment Position

Of the 93 Annex A controls assessed, 24 (26%) were rated Compliant, 44 (47%) were rated Partial or Opportunity for Improvement, and 25 (27%) were rated Non-Compliant. The Technological control category performed most poorly, with only 18% of controls fully compliant — a significant concern given that CyroPay's entire business model depends on secure, resilient technology infrastructure. The Organisational category likewise shows systemic gaps, with fewer than a third of controls fully compliant.

Three risks were assessed as Critical — scoring 16 or above on the 5×5 likelihood-impact matrix. These represent immediate threats to CyroPay's security posture and regulatory standing, and require remediation within 30 days. A further three risks scored 15 (High), with remediation required within 90 days. These findings are consistent with an organisation that has grown rapidly and has not yet formalised or matured its information security management practices to a level commensurate with the sensitivity of the data it holds and the regulatory environment in which it operates.

1.2 Positive Findings

The assessment did identify a number of areas of good practice that should be maintained:

- Physical security is well-managed, with CCTV, controlled entry, and appropriate server room access controls in place.
- AWS infrastructure is configured with multi-availability zone deployment and automated backups tested quarterly.
- HR processes — including pre-employment screening, NDAs, and exit checklists — are robust and consistently applied.
- FCA and ICO regulatory obligations are actively maintained, with current authorisation and registration confirmed.
- Source code is protected via GitHub with branch protection rules and restricted developer access.

1.3 Most Significant Concerns

The following issues represent the most material risks to CyroPay and require urgent attention from the Board:

- No Privileged Access Management (PAM) solution — shared admin credentials give any attacker who compromises a single account unrestricted access to all critical systems.
- MFA is not enforced across AWS, finance systems, or VPN — leaving the most sensitive access points protected by passwords alone.
- No formal vulnerability scanning or patch management SLA — systems may be carrying known, exploitable vulnerabilities.
- Live customer payment card data and PII is used in test environments without masking — a probable UK GDPR and PCI DSS violation requiring immediate remediation.
- No formal incident response plan exists — CyroPay cannot demonstrate compliance with FCA operational resilience requirements or DORA readiness.

2. Risk Register Summary

The following table summarises the 10 risks identified during the assessment. Risks are scored on a 5×5 likelihood-impact matrix (maximum score 25). Likelihood and Impact are scored 1 (Lowest) to 5 (Highest).

Risk ID	Description	L	I	Score	Rating	Owner	Target
R001	Privileged Access Management	4	5	20	Critical	IT Mgr	30 Jun 26
R002	Vulnerability & Patch Management	4	4	16	Critical	IT Mgr	31 Jul 26
R007	MFA Not Enforced Universally	4	4	16	Critical	IT Mgr	30 Jun 26
R003	Supplier Security Assessments	3	5	15	High	CISO	31 Aug 26
R004	Live Data in Test Environments	3	5	15	High	Head Dev	30 Jun 26
R005	Incident Response Plan Absent	3	5	15	High	CISO	31 Jul 26
R006	Data Classification Absent	3	4	12	Medium	DPO	31 Aug 26
R008	Security Awareness Training	4	3	12	Medium	HR Mgr	30 Sep 26
R009	Unencrypted Remote Laptops	3	4	12	Medium	IT Mgr	30 Jun 26
R010	Change Management Absent	3	4	12	Medium	IT Mgr	31 Aug 26

• CRITICAL ≥16	• HIGH 12–15	• MEDIUM 8–11	• LOW ≤7
----------------	--------------	---------------	----------

2.1 Risk Distribution

All ten identified risks have been assigned a treatment of Mitigate, reflecting the active steps required to reduce them to an acceptable level. No risks have been accepted, transferred, or avoided at this stage. The risk owner (typically the IT Manager or CISO) is accountable for delivery against the specified target date. These target dates should be tracked formally by the CISO and reported to the Board on a monthly basis until all Critical and High risks are closed.

It is important to note that the absence of a formal risk management framework means these 10 risks may not represent the full population of risks facing CyroPay. A comprehensive enterprise risk management programme, including regular risk identification workshops with all business areas, is recommended as part of the broader ISMS development effort.

3. Critical Risk Deep Dive

This section provides a detailed analysis of the three risks rated Critical. These require immediate management attention and remediation within 30 days. Failure to remediate these risks within the target timeframes should be escalated to the Board.

R001 Privileged Access Management (PAM) – Score 20			
Finding	Shared administrator credentials with no PAM tool, session recording, or just-in-time access controls are in use across payment processing systems, the customer database, and the AWS infrastructure. A single compromised account could result in total environment compromise.		
Action	Implement a PAM solution with session recording and just-in-time access. Eliminate all shared credentials within 30 days. Enforce individual named administrator accounts across all platforms.		
Owner	IT Manager	Target	30 Jun 2026
R002 Vulnerability & Patch Management – Score 16			
Finding	No scheduled vulnerability scanning programme or defined SLA for critical patch deployment exists. Systems are patched reactively, leaving CyroPay exposed to known exploits for extended periods. This increases the likelihood of a successful external attack significantly.		
Action	Deploy a vulnerability scanning tool and schedule monthly scans. Define a 72-hour SLA for critical patch deployment. Integrate scanning results into the change management process.		
Owner	IT Manager	Target	31 Jul 2026
R007 Multi-Factor Authentication Not Enforced – Score 16			
Finding	MFA is enabled only on Microsoft 365. AWS console, the finance system, and VPN access do not require MFA. This leaves the most sensitive and privileged access points protected only by passwords, which are vulnerable to phishing and credential-stuffing attacks.		
Action	Enforce MFA on all systems including AWS console, finance platform, and VPN within 30 days. Provide a corporate password manager. Technically enforce password complexity across all platforms.		
Owner	IT Manager	Target	30 Jun 2026

3.1 Compounding Risk Factors

The three Critical risks identified above are not independent. They interact and compound one another in ways that significantly increase CyroPay's overall exposure:

- Shared admin credentials (R001) combined with no MFA on AWS (R007) means that a single phished password could give an attacker complete control over CyroPay's cloud infrastructure — with no requirement to bypass a second authentication factor, and no PAM session recording to detect the intrusion.
- Unpatched vulnerabilities (R002) in an environment where admin access is uncontrolled (R001) dramatically increases the blast radius of any successful exploit.
- The absence of an incident response plan (R005, High) means that even if an attack occurred through these vectors, CyroPay would have no structured way to detect, contain, or report it — with direct implications for FCA operational resilience requirements and DORA notification obligations.

These three risks should therefore be addressed as an integrated programme, not as independent workstreams. The CISO should establish a dedicated Critical Risk Remediation Sprint with weekly progress reporting to the CEO.

4. ISO 27001:2022 Compliance Overview

This section summarises CyroPay's compliance posture across the 93 controls assessed in ISO 27001:2022 Annex A. Controls are assessed against three statuses: Compliant, Partial or Opportunity for Improvement (OFI), and Non-Compliant. The assessment is based on documentary evidence, staff interviews, and technical observation conducted in June 2025.

4.1 Compliance by Category

Category	Compliant	Partial / OFI	Non-Compliant	Total	Compliance %
Organisational	10	19	8	37	27%
People	4	2	2	8	50%
Physical	8	5	1	14	57%
Technological	6	18	10	34	18%
TOTAL	28	44	21	93	30%

4.2 Category Analysis

Organisational Controls (A.5)

With 37 controls assessed, this is the largest category and represents the governance backbone of the ISMS. Only 27% of controls are fully compliant. Key gaps include the absence of a formal information security policy suite, no supplier security programme, no incident management capability, and no independent review of the ISMS. The volume of Non-Compliant controls in this category reflects a systemic absence of formal governance structures rather than isolated lapses.

People Controls (A.6)

People controls represent the strongest compliance area, with 50% of controls fully compliant. Background screening, employment contracts with NDAs, and disciplinary processes are all well-established. However, the complete absence of a security awareness training programme (Non-Compliant) is a significant gap that undermines the effectiveness of all technical controls — staff cannot be expected to behave securely if they have not been trained to do so.

Physical Controls (A.7)

Physical security is the most mature area of the assessment, with 57% of controls fully compliant. The London office has appropriate access controls, CCTV, and server room restrictions. Key gaps are the absence of an off-premises asset security policy (relevant to 4 unencrypted remote laptops) and the lack of formal media handling procedures.

Technological Controls (A.8)

The Technological category is the most concerning, with only 18% of controls fully compliant. Of 34 controls assessed, 10 are fully Non-Compliant and 18 are Partial. Key Non-Compliant areas include privileged access management, vulnerability management, data masking, DLP, security testing (no penetration test in over two years), and information access restrictions. Given that CyroPay's business is entirely technology-dependent, this represents the highest-priority remediation area.

4.3 DORA Alignment

The Digital Operational Resilience Act (DORA) applies to CyroPay as a regulated financial entity. The assessment identified the following specific DORA-relevant gaps:

- No formal ICT risk management framework (Articles 5–16 of DORA).
- No digital operational resilience testing programme — no penetration test in over two years (Article 26).
- No ICT-related incident classification or reporting procedure capable of meeting DORA notification timelines (Articles 17–23).
- Third-party ICT risk management is absent — no vendor risk assessments or contractual security requirements aligned to DORA (Articles 28–44).

CyroPay should treat DORA compliance as a priority parallel workstream to the ISO 27001 remediation programme. A DORA gap assessment is recommended within 60 days to establish a formal compliance roadmap.

5. Remediation Roadmap

The following table sets out the 10 priority actions arising from this assessment, ordered by priority and target date. Actions are assigned to named owners accountable for delivery. The CISO is responsible for tracking overall programme progress and reporting to the Board monthly.

#	Action	Owner	Target	Priority
1	Implement PAM solution	IT Manager	30 Jun 2026	Critical
2	Enforce MFA across all systems	IT Manager	30 Jun 2026	Critical
3	Deploy vulnerability scanning tool	IT Manager	31 Jul 2026	Critical
4	Develop incident response plan	CISO	31 Jul 2026	High
5	Stop live data use in test envs.	Head of Dev	30 Jun 2026	High
6	Vendor risk assessment framework	CISO	31 Aug 2026	High
7	Data classification scheme	DPO	31 Aug 2026	Medium
8	Security awareness training	HR Manager	30 Sep 2026	Medium
9	Full-disk encryption – all laptops	IT Manager	30 Jun 2026	Medium
10	Formal change management process	IT Manager	31 Aug 2026	Medium

5.1 Immediate Actions (0–30 Days)

Three actions require immediate initiation and completion within 30 days. These address the Critical risks and a High risk with a June 2025 target:

- Implement PAM solution with session recording — IT Manager accountable.
- Enforce MFA across all systems including AWS, finance, and VPN — IT Manager accountable.
- Immediately prohibit use of live production data in test environments pending masking tool deployment — Head of Development accountable.
- Initiate full-disk encryption deployment on the four identified unencrypted remote laptops — IT Manager accountable.

5.2 Short-Term Actions (30–90 Days)

The following actions should be completed within 90 days and are assigned to the IT Manager and CISO as primary owners:

- Deploy vulnerability scanning tool and define patching SLA (R002) — IT Manager.
- Develop, document, and test formal incident response plan including FCA and ICO notification procedures (R005) — CISO.
- Develop and implement vendor risk assessment framework aligned to DORA (R003) — CISO.
- Develop four-tier data classification scheme and train all staff (R006) — Data Protection Officer.

5.3 Medium-Term Actions (90+ Days)

The following actions should be completed within six months:

- Implement formal change management process (R010) — IT Manager.
- Deliver mandatory security awareness training with phishing simulation testing (R008) — HR Manager.
- Commission external penetration test and integrate DAST scanning into CI/CD pipeline (Annex A gap).
- Establish annual internal ISMS audit programme and commission external assessment (A.5.35).

6. Conclusions

CyroPay operates in a high-risk data environment, processing payment card data and personal information for thousands of customers under FCA authorisation and UK GDPR obligations. The findings of this assessment indicate that the organisation's current information security posture does not adequately reflect these responsibilities.

The three Critical risks — absent PAM, absent MFA on key systems, and reactive vulnerability management — represent a combination that, if exploited, could result in complete infrastructure compromise with no reliable means of detection, containment, or regulated notification. This is not a theoretical concern: organisations with this profile are actively targeted by financially-motivated threat actors, including ransomware groups.

The path forward is clear. CyroPay must treat information security as a business-critical programme, not an IT function. The Board must formally endorse the ISMS, resource it appropriately, and hold the CISO accountable for measurable remediation progress. The 10 actions identified in this report, if delivered to schedule, will materially reduce CyroPay's risk exposure and move the organisation substantially closer to ISO 27001:2022 certification readiness within 12 months.

GRC Advisory is available to support CyroPay through the implementation phase, including policy development, technical remediation oversight, staff training delivery, and pre-certification audit preparation.

Document Control

Version 1.0 | June 2025 | Classification: CONFIDENTIAL

Prepared by Oluwagbemiga Samuel Ibijura | Approved for distribution to Board and Senior Leadership Team only

This document is commercially sensitive. Do not distribute beyond the intended audience.